

Attaque par force brute sur DVWA BELIDA Chaina

Formation : BTS Services Informatiques aux Organisations Option SLAM

Année : 2026

Établissement : Paris Ynov Campus

Encadrant : Madame EL KHADAR

1. Présentation

Ce TP consiste à exploiter une vulnérabilité de type **Brute Force** sur l'application **DVWA** (Damn Vulnerable Web Application) installée sur Kali Linux.

Contexte

- Cours / Formation : U7 Cybersécurité
- Date : 03/03/2026
- Modalité : Individuel
- Durée : 2h



Cadre légal & éthique : ce TP doit être réalisé **uniquement** sur l'environnement DVWA prévu (local / VM) et avec autorisation. Toute tentative sur un système réel non autorisé est interdite.

2. Objectifs pédagogiques

- Comprendre le principe d'une attaque par force brute et ses limites
- Identifier les éléments d'un formulaire d'authentification vulnérable
- Exploiter la vulnérabilité en difficulté **Low**
- Utiliser **Burp Suite (Intruder)** pour automatiser l'attaque
- Analyser les réponses serveur (codes HTTP, longueur, contenu)

3. Pré-requis & environnement technique

Matériel / VM

- VM Kali Linux
- DVWA installé en local

Services

- Apache démarré
- MariaDB démarré

Outils

- Burp Suite

Identifiants

- Kali : `kali / kali`
 - DVWA : `admin / password`
-

4. Mise en place de l'environnement

4.1 Démarrer les services

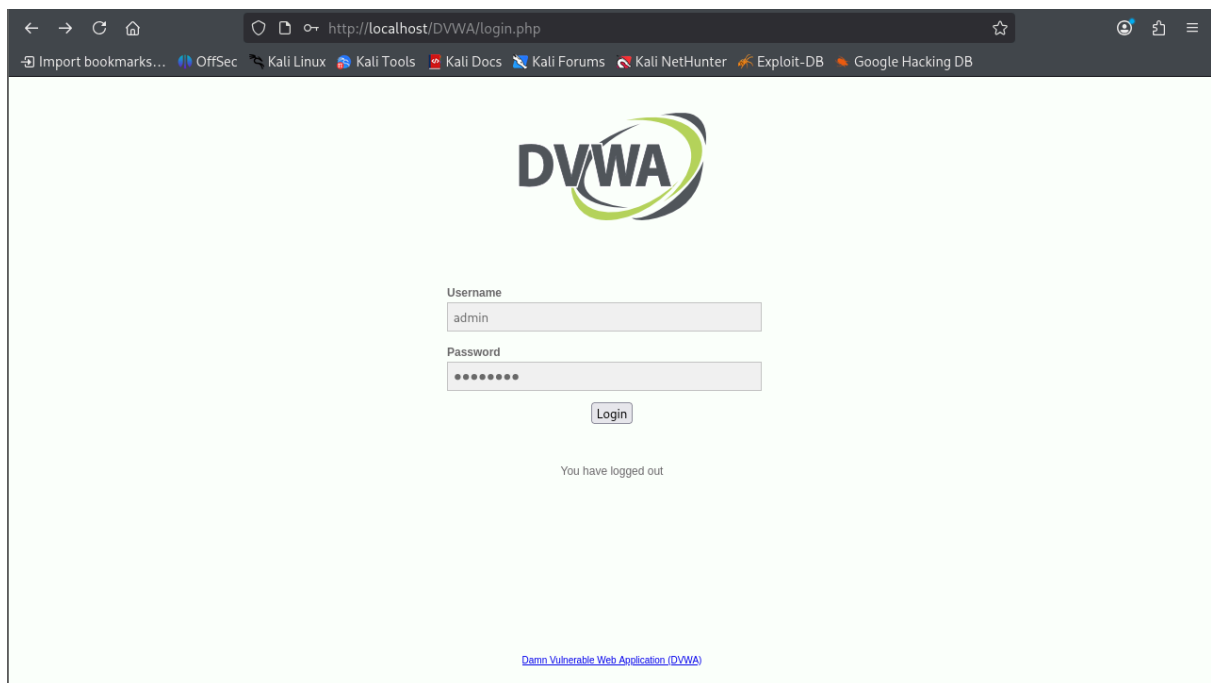
```
sudo systemctl start apache2
sudo systemctl status apache2
sudo service mysql start
sudo service mysql status
```

4.2 Accéder à DVWA

```
http://localhost/setup.php
```

Initialiser la base si nécessaire.

Capture – Page login DVWA



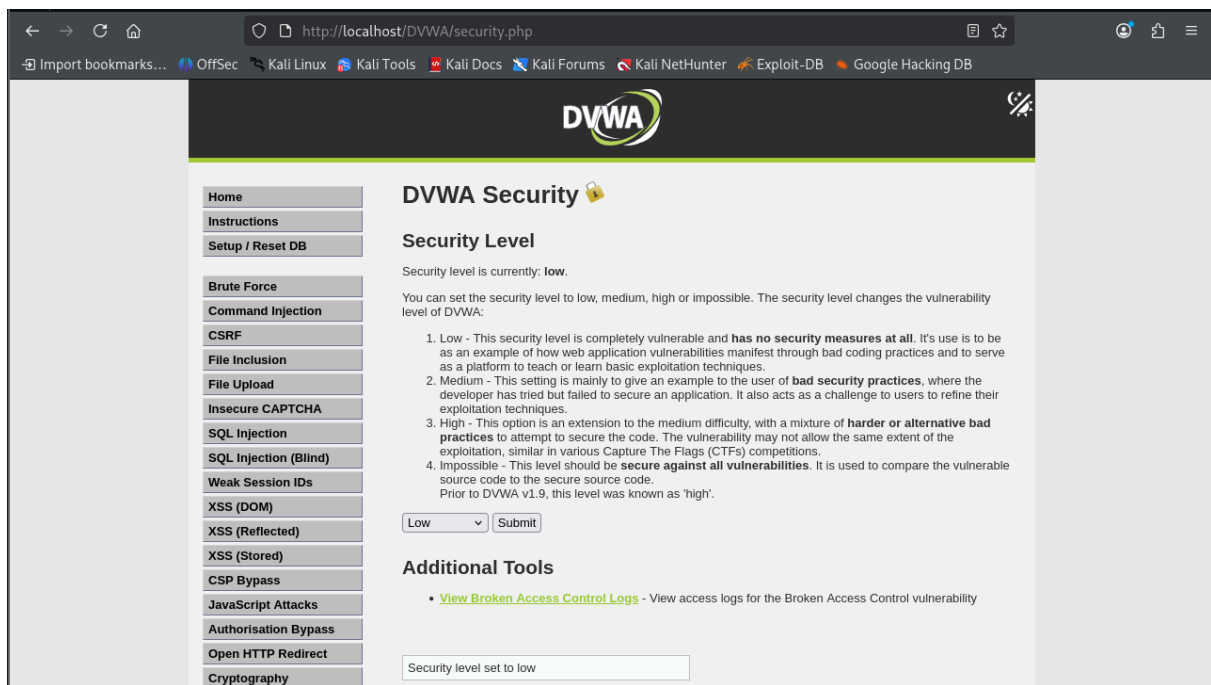
5. Configuration du niveau de sécurité (DVWA)

1. Se connecter à DVWA avec :

```
admin
password
```

1. Navigation : **DVWA Security** → Sélectionner **Low** → **Submit**

Capture – Niveau Security Low



6. Reconnaissance : observer le comportement de l'authentification

Aller dans : **Vulnerability** → **Brute Force**

Tester manuellement :

- `admin / password` (cas « succès »)
- `admin / mauvaispassword` (cas « échec »)

À observer :

- Message d'erreur / succès
- Différences de contenu entre succès et échec
- Redirections éventuelles
- Codes HTTP / taille de réponse (si visible)

7. Analyse du code & découverte d'informations

7.1 Inspecter la page

Clic droit → **Inspector** (Inspect Element)

Repérer par exemple :

```
src=/hackable/users/admin.jpg
```

7.2 Lister les utilisateurs exposés

Accéder à :

```
http://localhost/hackable/users/
```

Utilisateurs observés :

- admin
- gordonb
- pablo
- smithy
- 1337

Capture – Index of /hackable/users

Index of /DVWA/hackable/users

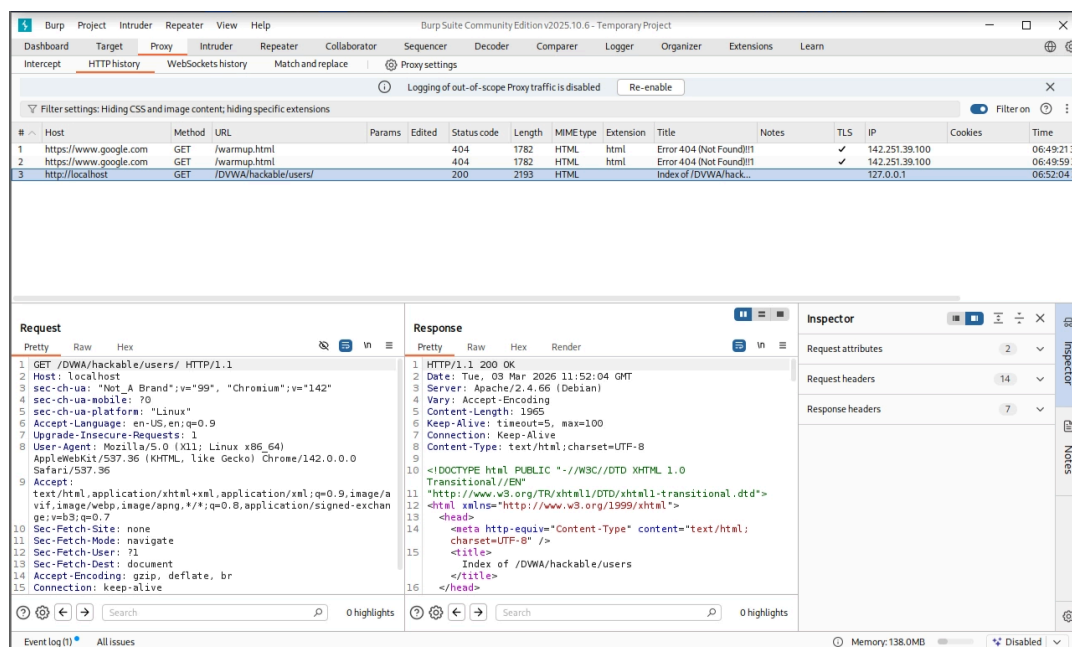
Name	Last modified	Size	Description
 Parent Directory	-		
 1337.jpg	2026-03-03 05:30	3.6K	
 admin.jpg	2026-03-03 05:30	3.5K	
 gordonb.jpg	2026-03-03 05:30	3.0K	
 pablo.jpg	2026-03-03 05:30	2.9K	
 smithy.jpg	2026-03-03 05:30	4.3K	

Apache/2.4.66 (Debian) Server at localhost Port 80

8. Burp Suite : préparation

1. Ouvrir **Burp Suite**
2. Onglet **Proxy**
 - Vérifier que **Intercept is off**
 - Cliquer sur **Open Browser**
3. Ajouter la cible au scope :
 - **Target** → clic droit sur l'hôte → **Add to scope**

Capture – Burp Proxy ouvert



9. Capture de la requête Brute Force (Burp)

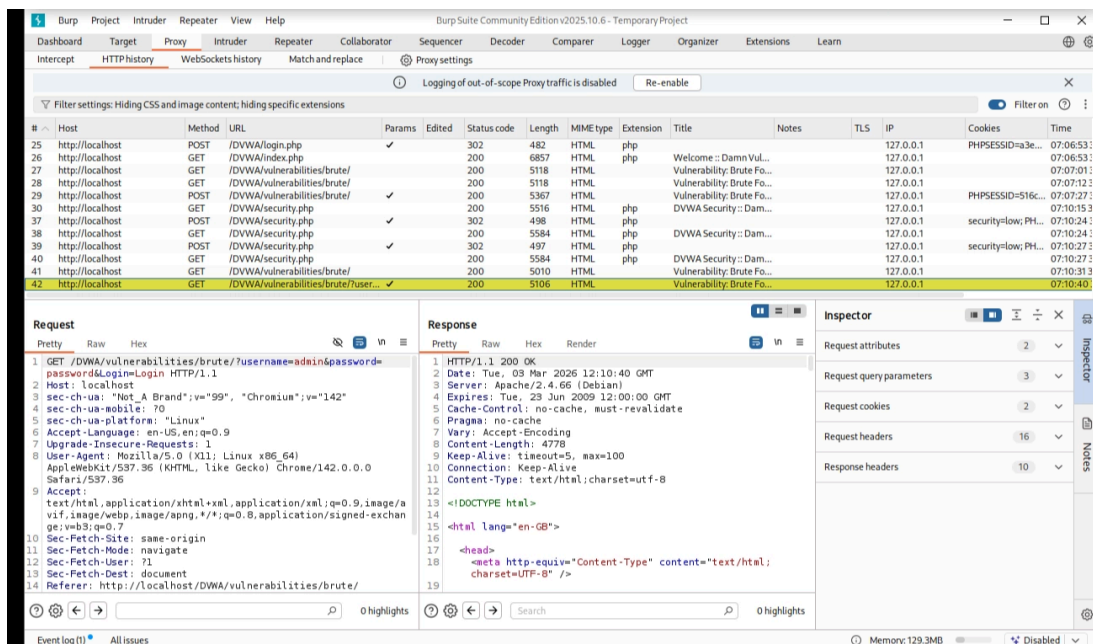
Dans le navigateur Burp :

- faire un login (succès ou échec) dans **Vulnerability** → **Brute Force**

Dans Burp :

1. **Proxy** → **HTTP history**
2. Identifier la requête correspondant au login
3. Clic droit :
 - **Highlight** (optionnel)
 - **Send to Intruder**

Capture – Paquet responsable du login



10. Intruder : configuration de l'attaque

Dans l'onglet **Intruder** :

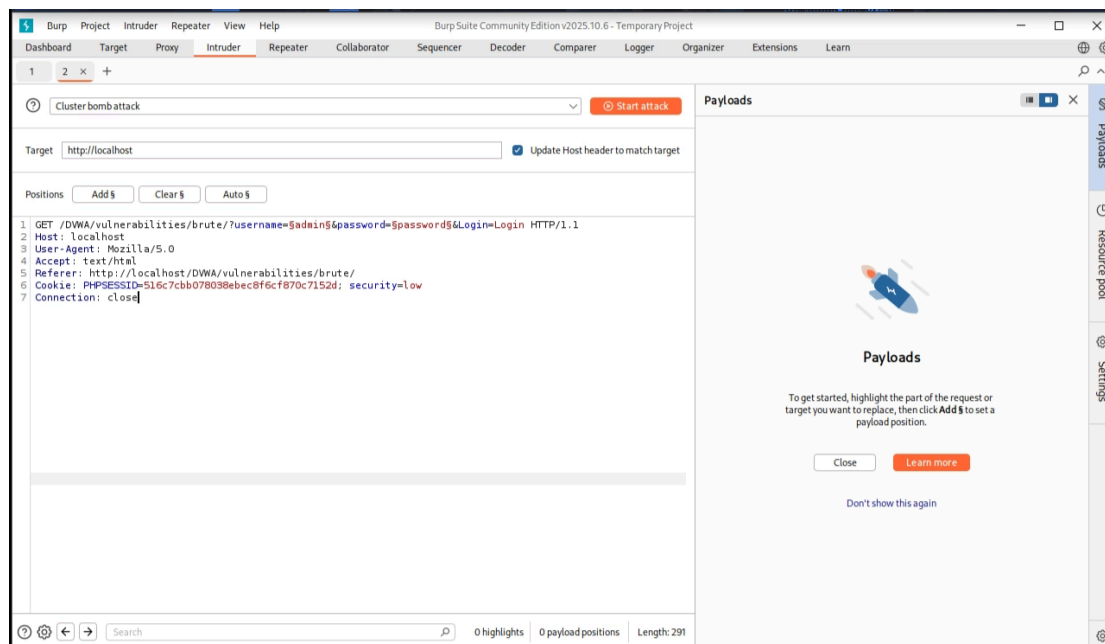
- **Attack type** → **Cluster bomb**

Définir les positions (variables) dans la requête :

```
username=$admin$
password=$password$
```

Supprimer les autres § si Burp en a ajouté.

Capture – Cluster Bomb Attack

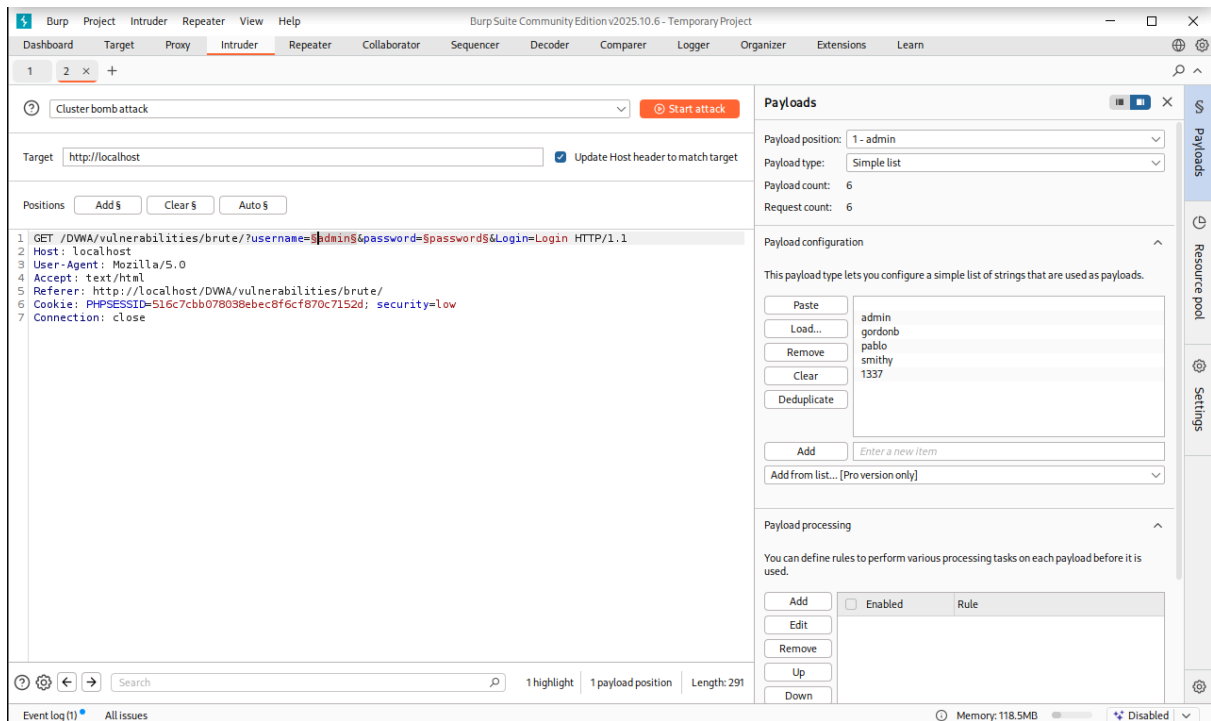


11. Intruder : configuration des payloads

11.1 Payload set 1 — Username

- **Payload set** : 1
- **Payload type** : Simple list
- **Ajouter** :
 - admin
 - gordonb
 - pablo
 - smithy
 - 1337

Capture – Payloads Username

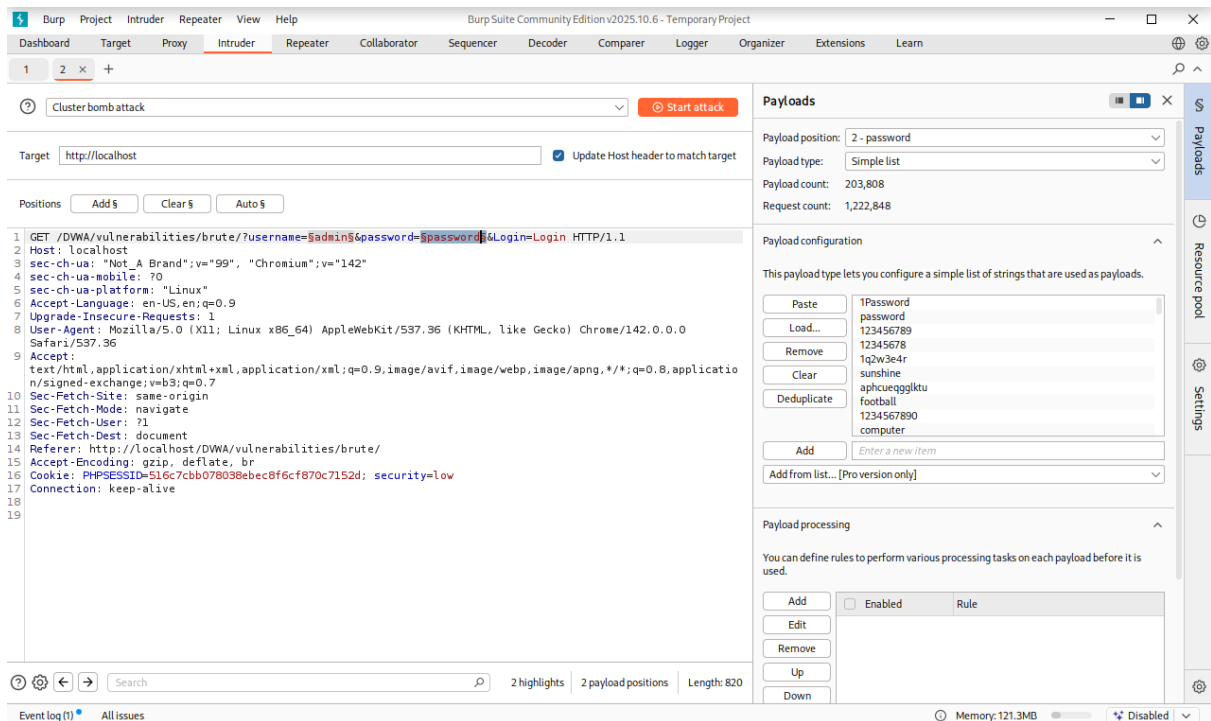


11.2 Payload set 2 — Password

- **Payload set** : 2
- **Payload type** : Simple list
- Charger le fichier :

```
/usr/share/dict/wordlist-probale.txt
```

Capture – Payloads Password



12. Lancement de l'attaque & analyse des résultats

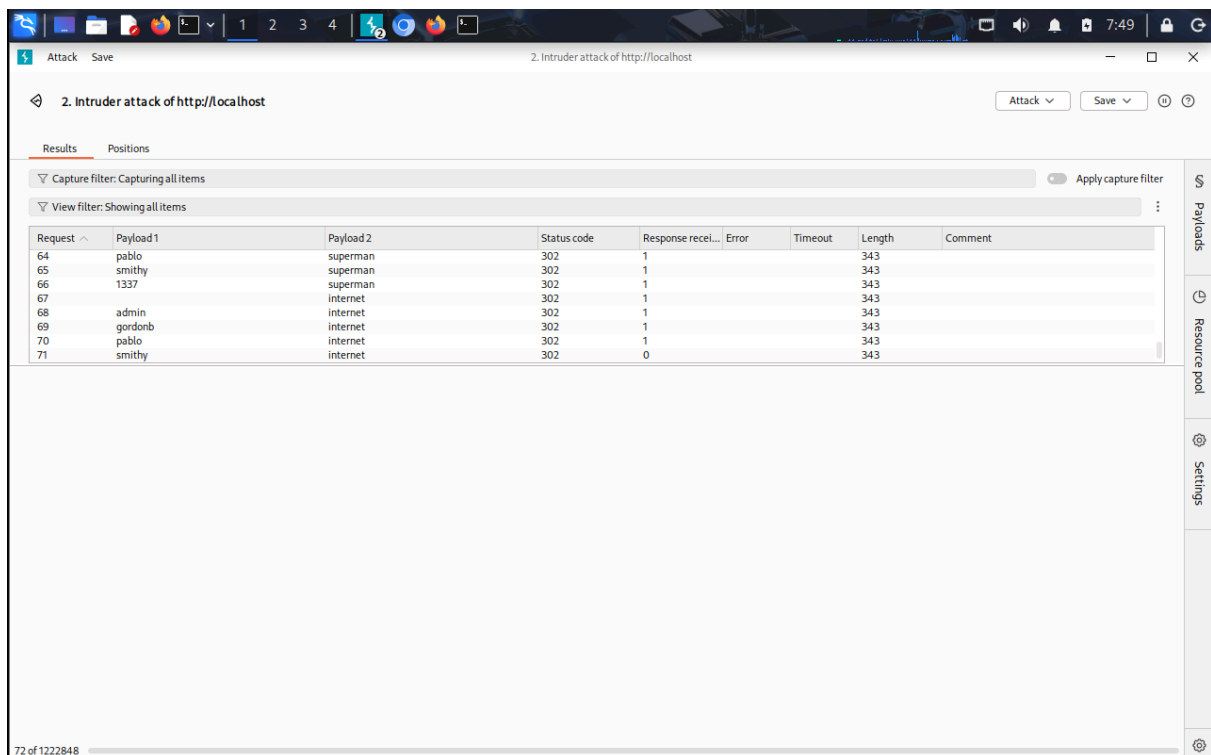
Cliquer sur **Start attack**.

À analyser dans les résultats Intruder :

- **Status code** (ex. 200, 302...)
- **Length** (longueur de réponse)
- Différence de contenu (message d'erreur vs succès)

Indicateur pratique : en brute force, un succès se repère souvent par une longueur de réponse différente, un code 302, ou l'apparition d'un message spécifique.

Capture – Résultats Intruder



13. Variante : difficulté Medium

1. Changer le niveau : **DVWA Security** → **Medium**
2. Reprendre l'exercice
3. Lire **View Help** pour comprendre ce qui change
4. Comparer avec *Low* :
 - présence de protections (ex. limitation, tokens, messages uniformisés...)
 - impact sur l'attaque Intruder (succès/échec, bruit, stabilité)

14. Outils alternatifs (optionnel)

Tester et comparer :

- **wfuzz**
- **hydra**

Objectif : comprendre les différences entre un outil « proxy + intruder » (Burp) et des outils spécialisés de brute force.

15. Remédiations (à retenir)

Mesures classiques contre la force brute :

- Limitation de débit (rate limiting) / temporisation progressive
 - Verrouillage temporaire du compte après N tentatives
 - CAPTCHA / défis adaptatifs
 - MFA (authentification multi-facteur)
 - Messages d'erreur uniformisés (ne pas révéler si l'utilisateur existe)
 - Journalisation & alerting sur tentatives répétées
-

16. Conclusion

Ce TP a permis :

- d'illustrer une attaque par force brute sur une application volontairement vulnérable (DVWA) ;
- d'utiliser **Burp Suite** pour capturer et rejouer des requêtes HTTP ;
- d'identifier les critères qui permettent de distinguer un succès d'un échec ;
- de comprendre l'intérêt de mécanismes de protection (Low vs Medium).